

2.7. Security

Matter deploys robust security practices to protect the Fabric. Matter designates a core set of security primitives detailed in [Chapter 3, *Cryptographic Primitives*](#) to provide comprehensive protection. Elliptic curve cryptography, based on the NIST P-256 curve (secp256r1) serves as the foundation for public key cryptography and digital signatures. Commonly available AES modes of operation have been selected to provide shared key cryptographic operations. In scenarios involving an out-of-band passcode-based authentication, Matter uses SPAKE2+, an efficient augmented PAKE algorithm.

The core cryptographic primitives form the basis of a number of complementary secure protocols used within Matter. All unicast Node-to-Node messages are secured, authenticated, and provide replay protection. Building on top of IPv6 multicast, Matter also provides secured group messaging facilities, useful for efficiently addressing on an LLN. The group messaging features prioritize low latency of packet processing.

2.8. Device Commissioning

Device commissioning (see [Chapter 5, *Commissioning*](#)) is the process of joining a device to a Fabric. The device being commissioned is referred to as the Commissionee and the device administering commissioning is referred to as the Commissioner. Device commissioning consists of the following steps:

1. Device discovery (see [Section 5.4, “Device Discovery”](#) and see [Section 5.1, “Onboarding Payload”](#)): The Commissioner discovers commissionable devices on network interfaces such as Bluetooth Low Energy, Wi-Fi, or other connected IP network. The Commissioner obtains the out-of-band secret ([Section 5.1.1.6, “Passcode”](#)) from the commissionable device’s [Section 5.1.3, “QR Code”](#), [Section 5.1.4, “Manual Pairing Code”](#), [Section 5.1.8, “NFC Tag”](#) or other means. This secret is used by [Section 4.14.1, “Passcode-Authenticated Session Establishment \(PASE\)”](#) to establish a secure commissioning session. The order of discovering commissionable devices and obtaining the out-of-band secret from commissionable device is not critical.
2. Security setup with PASE (see [Section 4.14.1, “Passcode-Authenticated Session Establishment \(PASE\)”](#)): Establish encryption keys between the Commissioner and Commissionee using PASE. All messages exchanged between the Commissioner and Commissionee are encrypted using these PASE-derived keys. The process also establishes an attestation challenge used during the [device attestation procedure](#).
3. Device attestation verification (see [Section 6.2, “Device Attestation”](#)): Commissioner establishes the authenticity of the Commissionee as a certified device, notifying the user if the device is not certified.
4. Information configuration (see [Section 6.4, “Node Operational Credentials Specification”](#), [Section 11.10, “General Commissioning Cluster”](#) and [Section 11.18, “Operational Credentials Cluster”](#)): The Commissioner provides Commissionee with information such as regulatory domain, UTC time, Operational Certificate and network interfaces configuration.
5. Join network (see [Section 11.9, “Network Commissioning Cluster”](#) and [Section 4.3.2, “Operational Discovery”](#)): The Commissioner triggers the Commissionee to connect to the operational network unless the Commissionee is already on the operational network. The Node’s/Commissionee’s IPv6 address is then either used (if already known) or discovered (if not known) by the